



FUNDAMENTALS OF INFORMATION SECURITY

SESSION 3

COURSE CODE:

CYBE 6123

LECTURER: **NGUEMETA NATHANIEL**



Risk, Threat and Vulnerability

Information Security Risk

ISO/IEC 27000, clause 3.61

- *Note 4 to entry: Risk is often expressed in terms of a combination of the consequences of an event (including changes in circumstances) and the associated “likelihood” of occurrence.*
- *Note 5 to entry: In the context of information security management systems, information security risks can be expressed as effect of uncertainty on information security objectives.*
- *Note 6 to entry: Information security risk is associated with the potential that threats will exploit vulnerabilities of an information asset or group of information assets and thereby cause harm to an organization.*



The Risk Management Process.

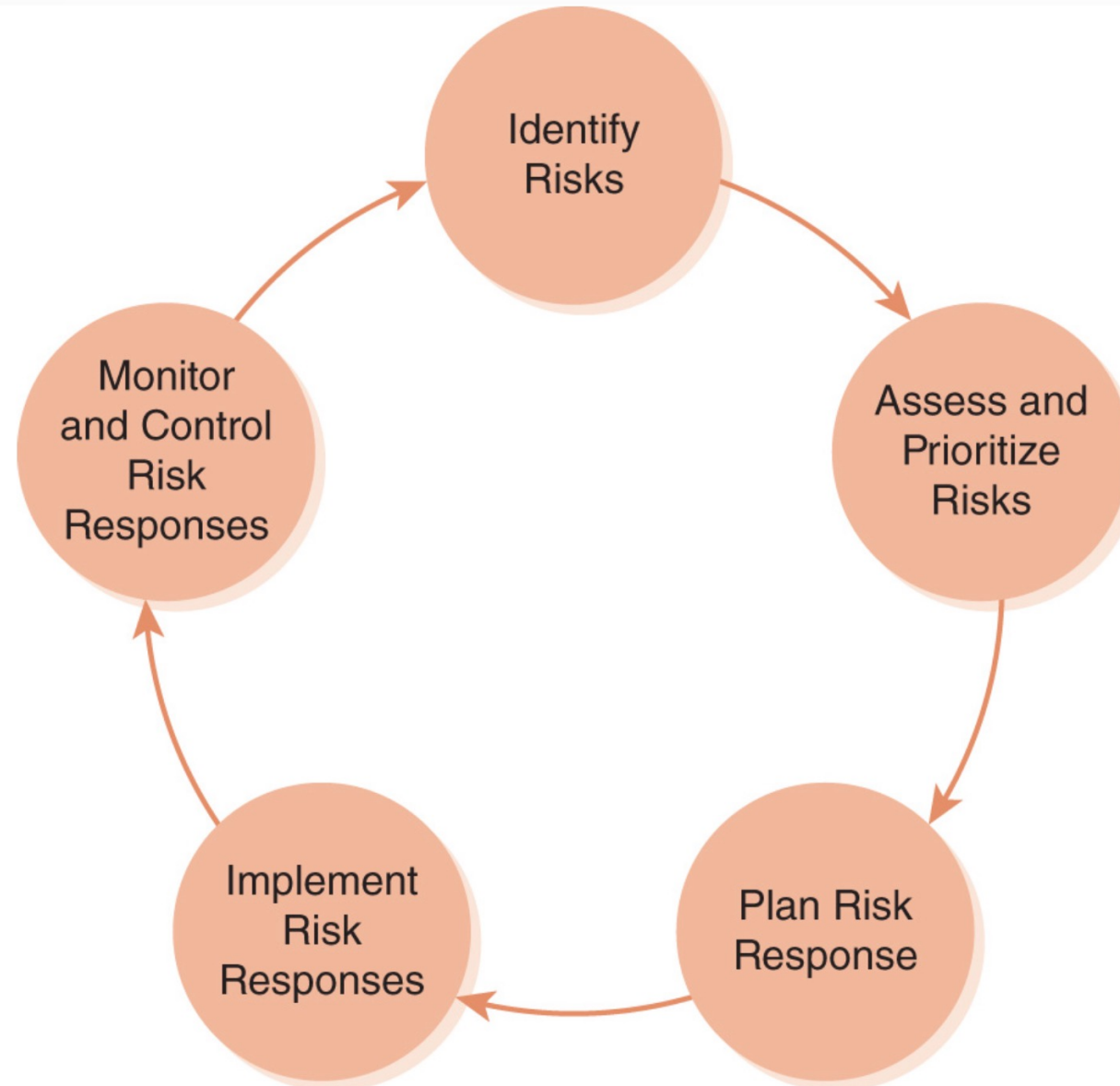


FIGURE 3-1 Risk management process.

Identify risks

- The first step to managing overall risk is to identify the individual risks.
- develop scenarios for each risk to assess the threats
- Examples:
 - fire,
 - flood,
 - earthquake,
 - lightning strike,
 - loss of electricity or other utility,
 - communication interruption
 - labor strike,
 - pandemic,
 - transportation unavailability.

Methods to Identify risks

- **Brainstorming**—This technique involves getting unstructured input from members of the organization in a group meeting.
- **Surveys**—Organizations that use surveys send lists of prepared questions to a variety of people from different areas of the organization for input.
- **Interviews**—Interviews, held in either group settings or one on one, can be an effective approach to gather details on risks from the interviewee's perspective.
- **Working groups**—This technique focuses on soliciting feedback from a group of individuals selected from a specific work area to help identify risks in that area.
- **Checklists**—Many organizations develop checklists of risks for either their own use or general distribution.
- **Historical information**—Unless an organization is brand new, it will have some historical information at its disposal.

Risk Register



The result of the risk identification process is a list of identified risks

- The risk register should contain at minimum:
 - A description of the risk
 - The expected impact if the associated event occurs
 - The probability of the event's occurring
 - Steps to mitigate the risk
 - Steps to take should the event occur
 - Rank of the risk

Risk Register

Risk Management											
ID	Brief Risk Description	Risk Category	Response Action/ Strategy	Response Action/ Strategy Description	Responsible Individual	Monitoring and updating			Post-treatment risk rating		
						Trigger Event(s)	Status	Risk Resolution Date	Impact	Likelihood	Risk Rating
Auto	Auto	Auto	Drop Down	Manual	Manual	Manual	Drop Down	Manual (MM/DD/YY)	Drop Down	Drop Down	Auto

FIGURE 3-2 Sample risk register.

Assess and prioritize risks

- Risk treatment should support business objectives
- Not all risks apply to all businesses in all locations.
- Some risks pose a greater possibility of loss or interruption than others.
- Identify aggravating factors and impute them within the assessment
- Consider attenuating circumstances and/or existing controls
- Consider affected business processes when prioritizing
- Key aspects are: impact, likelihood of occurrence, or time and cost to remediate.

Approaches for Risk Assessment

- **Quantitative risk assessment**

- Considers cost or value of the identified risk
- Impact is calculated in terms of numbers
- Easy to automate
- Less subjective and easily computed

- **Qualitative risk assessment**

- Considers applied rating of risk in terms of range
- Impact is the degree of effect a realized threat would pose
- often expressed from low (insignificant) to high (catastrophic)
- Often subjective and based on personal judgement

Quantitative	Numerically based (hard) data	Financial data (objective)
Qualitative	Scenario-based (soft) data	Scenario-oriented (subjective)

FIGURE 3-3 Quantitative versus qualitative risk assessments.

Quantitative Risk Assessment

- The value of the asset and the probability that a loss will be encountered must be assessed.
(event's **loss expectancy**)
 1. Calculate the asset value (AV)
 2. Calculate the exposure factor (EF)
 3. Calculate the single loss expectancy (SLE)
 4. Determine how often a loss is likely to occur every year (ARO)
 5. Determine annualized loss expectancy (ALE)

CALCULATION

FORMULA

Single loss expectancy (SLE)

$$AV \times EF = SLE$$

Annualized rate of occurrence
(ARO)

ARO = Number of incidents per
year

Annualized loss expectancy (ALE)

$$SLE \times ARO = ALE$$

Plan a Risk Response Strategy

Negative Risk Response

- Reduce (reduction/mitigation)
- Transfer (transference/assignment)
- Accept (acceptance)
- Avoid (avoidance)

Positive Risk Response

- Exploit (exploitation)
- Share (sharing)
- Enhance (enhancement)
- Accept (acceptance)

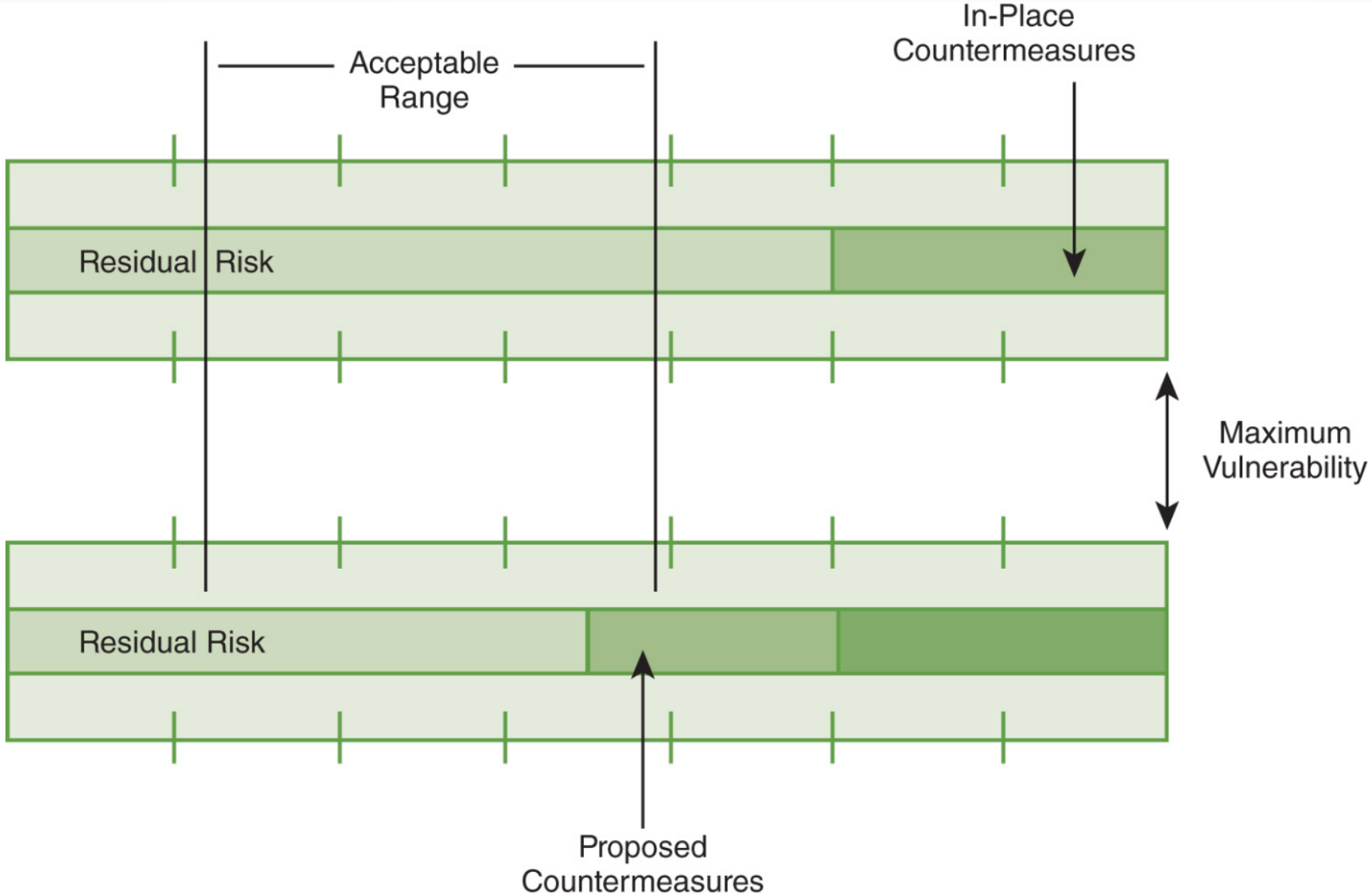


FIGURE 3-5 Acceptable range of risk.

Security Controls

Classification by type

Technical control

Controls related to the use of technical measures or technologies, such as firewalls, alarm systems, surveillance cameras, etc.



Legal control

Controls related to the application of a legislation, regulatory requirement, or contractual obligations



Administrative control

Controls related to organizational structure, such as segregation of duties, job rotations, job descriptions, approval processes, etc.



Managerial controls

Controls related to the management of personnel, including training of employees, management reviews, internal audits, etc.



Implement Controls

Detective controls

Identify that a threat has landed in a system.

Example:

Intrusion detection system (IDS)

Preventive controls

Stop threats from coming into contact with a vulnerability.

Example:

Intrusion prevention system (IPS)

Corrective controls

Reduce the effects of a threat.

Example:

- Forensics
- Incident response

Deterrent controls

Deter an action that could result in a violation.

Example:

- Cable Locks.
- Hardware Locks.
- Video surveillance & guards.
- Suspension
- Fines or penalties

Compensating controls

Implemented to address a threat in place that does not have a direct risk-mitigating solution.

Example:

Intrusion detection system (IDS)

Evaluating the Cost of a Countermeasure



- **Product costs**—The price of the product will include its base price, the price of additional features, and costs associated with the service-level agreements and maintenance
- **Implementation costs**—Implementation costs refer to those associated with changes to the infrastructure, construction, design, and training.
- **Compatibility costs**—The countermeasure must fit within (be compatible with) the overall structure.
- **Environmental costs**—If, for example, a countermeasure uses a lot of energy, consideration must be given to whether the electrical system would be able to provide that energy and to offset the excess heat it will generate.
- **Testing costs**—Testing takes time and money and causes disruptions, the costs of which must be considered.
- **Productivity impact**—Many controls affect productivity, such as generating more calls to the help desk or slowing response times for users.

Monitor and Control Risk response

- It is Important to make sure any countermeasure meets its objectives
- It is essential to set measurement criteria and monitor their performance

Best practices include:

- Countermeasures might pose a new risk to the organization
 - Make sure the countermeasure is continuously monitored, checked for compliance and good design, and regularly maintained.
- Perform certification and accreditation of countermeasure programs
 - All systems, controls, and applications should first go through a change control process before going into production
- Follow best practices and exercise due diligence
 - Frequently evaluating whether countermeasures are performing as expected.

Risks to the IT Infrastructure

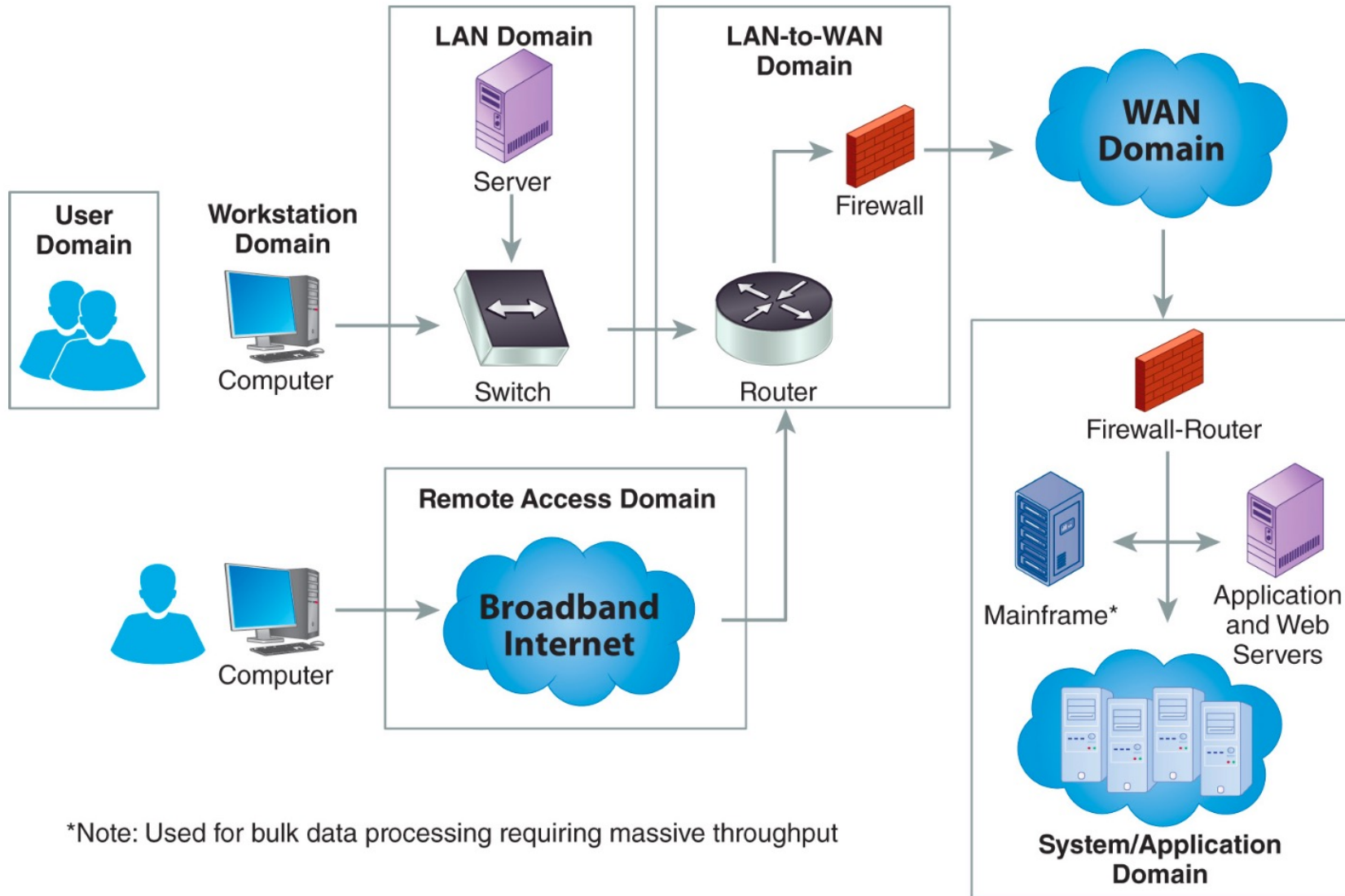


FIGURE 3-7 The seven domains of a typical IT infrastructure.

Risks to the IT Infrastructure



- Intellectual Property (IP) and data breaches
 - Loss of confidentiality of IP or critical data can nullify an organization's competitive advantage.
- Finances and Financial Data
 - Loss of financial assets due to malicious attacks can represent significant physical loss and can also have long-term effects on a company's reputation and brand image.
- Service Availability and Productivity
 - Malicious attacks can occur and cause downtime in any of the seven domains of a typical IT infrastructure
- Reputation
 - Negative public perception could lead to a decline in the organization's revenue, net worth, and market capitalization.

Main Threat Actors



- **Black-hat hackers**—Black-hat hackers try to break IT security and gain access to systems with no authorization in order to prove technical prowess or potentially steal sensitive data.
- **White-hat hackers**—White-hat, or ethical, hackers are information systems security professionals who have authorization to identify vulnerabilities and perform penetration testing.
- **Gray-hat hackers**—Gray-hat hackers are hackers with average abilities who may one day become black-hat hackers but could also opt to become white-hat hackers.

Main Threat Types

- Disclosure threats
 - Sabotage—Sabotage is the destruction of property or obstruction of normal operations.
 - Espionage—Espionage is the act of spying to obtain secret information, typically to aid another nation-state.
- Alteration threats
 - A system can be compromised by making unauthorized changes to data, either intentionally or unintentionally.
 - Modifications to the system configuration can also compromise the integrity of a network resource.
- Denial or destruction threats
 - Prevents an authorized user from accessing a resource, either temporarily or permanently.

Malicious Attacks



- **Fabrications**—Fabrications involve the creation of some deception in order to trick unsuspecting users.
- **Interceptions**—Interceptions involve eavesdropping on transmissions and redirecting them for unauthorized use.
- **Interruptions**—Interruptions cause a break in a communication channel, which blocks the transmission of data.
- **Modifications**—Modifications are the alteration of data contained in transmissions or files.

Active Threats

- Birthday attacks
- Brute-force password attacks
- Credential stuffing
- Dictionary password attacks
- IP address spoofing
- Hijacking
- Replay attacks
- Man-in-the-middle attacks
- Masquerading
- Social engineering
- Phreaking
- Phishing
- Pharming

Attack Vectors

- An attack vector, or threat vector, is a way for attackers to enter a network or system
 - **Attacks on availability**—These attacks impact access or uptime to a critical system, application, or data.
 - **Attacks on people**—These attacks involve using coercion or deception to get another human to divulge information or to perform an action
 - **Attacks on IT assets**—These attacks include penetration testing, unauthorized access, privileged escalation, stolen passwords, deletion of data, or performing a data breach.

Social Engineering Attacks



- Authority
- Consensus/social proof
- Dumpster diving
- Familiarity/liking
- Hoaxes
- Impersonation
- Intimidation
- Scarcity
- Shoulder surfing
- Smishing
- Tailgating
- Trust
- Trusted users
- Urgency
- Vishing
- Whaling

Wireless Network Attacks

- Bluejacking
- Bluesnarfing
- Evil twin
- Jamming/interference
- Near field communication attack
- WEP/WPA Encryption Attack
- Packet sniffing
- Replay attacks
- Rogue access points
- War chalking
- War driving

Web Application Attacks



- Arbitrary/remote code execution
- Buffer overflow
- Client-side attack
- Cookies and attachments
- Cross-site scripting (XSS)
- Cross-site request forgery (CSRF)
- Directory traversal/command injection
- Header manipulation
- Integer overflow
- Lightweight Directory Access Protocol (LDAP) injection
- Local shared objects (LSO)
- Malicious add-ons
- SQL injection
- Watering-hole attack
- XML injection
- Zero day

Assignment

- Provide 5 reasons why countermeasures are important and explain briefly
- Complete and submit assessment.



Thank You